Commerce & International Data Transfers

September 2025

Commerce

Commerce

Commerce believes the privacy and data protection of our merchants and their customers is of utmost importance. We comply with leading data protection laws around the world, including the General Data Protection Regulation (EU) 2016/679 (GDPR).

When acting as a processor, Commerce reviews all data transfers for security, privacy, and transfer impact. Commerce only transfers the personal data of European residents to countries that lack an adequacy decision if both of the following conditions are met: (i) the Standard Contractual Clauses (SCCs) approved by the European Commission apply; *and* (ii) the security and organizational safeguards implemented by the data importer adequately protect the personal data.[1]

This document provides general information about our data transfer practices and answers some of the most common questions that we receive about how Commerce complies with GDPR.

Commerce's GDPR Compliance Regime

Commerce's Technical and Organizational Security Safeguards

Consistent with Article 32 of GDPR, Commerce maintains a comprehensive Information Security Management System (ISMS). Commerce also operates a comprehensive Privacy Information Management System (PIMS) and Business Continuity Management System (BCMS). Fundamentally, these systems are designed to help Commerce understand and manage what data it has, where the data is located, and how the data is used and protected.

Commerce's ISMS is audited and certified annually by an independent third-party as meeting or exceeding International Organization for Standardization's ISO/IEC 27001 standards (ISO 27001). Commerce's System and Organization Controls (SOC) are also audited annually by an independent third-party against the standards promulgated under the American Institute of Certified Public Accountants' Statement on Standards for Attestation Engagements (SSAE).

Commerce's most recent ISO 27001 certification and SOC reports, as well as extensive additional information about our ISMS, are available on our Platform Trust Center and Commerce Infrastructure and Platform Security Guide Whitepaper. Highlights include:

- **Encryption**. Commerce encrypts your data by default, in-transit and at-rest.
- **Security & Penetration Testing**. Commerce conducts frequent vulnerability scans and engages third-party providers to regularly conduct penetration tests and vulnerability assessments. We also crowdsource and empower any security researcher to test our platform's security by participating in a bug-bounty program.
- **24/7 Cybersecurity**. Commerce's secure-by-design infrastructure includes perimeter and host-based firewalls, file integrity monitoring, intrusion detection, application firewalls and 24/7 monitoring by our global cybersecurity team. Our infrastructure is also designed to promote real-time resilience and disaster recovery.
- **Minimisation of Personal Data.** Commerce strives to minimise personal data collected by our platform. To the extent practicable, we take measures to anonymise, pseudonymise, aggregate, and/or deidentify personal data consistent with Article 25 of GDPR.

[1] GDPR, Art. 46.

EU-US Data Privacy Framework

As part of Commerce's ongoing commitment to data protection, we actively and voluntarily participate in the EU-US Data Privacy Framework (DPF) including the UK and Swiss extensions for listed entities within our family of companies. This provides a mechanism for the lawful transfer of personal data between the EMEA area and the United States. Following the framework, Commerce ensures that any data transfers to the U.S. follow the principles of the DPF, which address key concerns raised in the Schrems II ruling. By participating in this framework, Commerce is bound to uphold rigorous privacy safeguards, including transparency and the protection of data subjects' rights. This participation reinforces our dedication to safeguarding personal data and provides an additional layer of assurance to our merchants and their customers that their data is handled responsibly and securely. We continue to monitor developments in data protection laws and adapt our practices to ensure ongoing compliance and the highest standards of privacy protection.

The Standard Contractual Clauses with Commerce & Our Subprocessors

Our Data Processing Agreement (DPA) includes the SCCs as well as other important contractual data protection commitments, including technical and organisational security measures, between you and Commerce. All transfers between Commerce affiliates are governed by an internal Intra-Group Data Transfer Agreement (IGA) that contains substantially the same data protections as those found in our DPA.

Commerce does not transfer any personal data to subprocessors without: (i) a security assessment, (ii) a privacy assessment (iii) assessing the impact of a data transfer review of data transfer impact; (iv) a written data protection agreement that contains substantially the same data protections as those found in our DPA; *and* (v) the SCCs with supplementary technical and organisational security measures (if data might be exported from the EU).[2] Where practical, we may execute the SCCs even with adequate jurisdictions so that transfers remain valid if adequacy changes. Our ISMS and PIMS require security and privacy reviews of all subprocessors both prior to onboarding and at regular intervals thereafter.

Optional Additional Measures You Can Take to Minimise Data Transfer Concerns

As described further in the FAQs below, Commerce makes regional hosting available for merchants interested in hosting their stores in Europe or the Asia-Pacific (APAC) region rather than in the United States. The Commerce platform also provides merchants with latitude and functionality to control the personal data that their store collects, uses, and retains.

For merchants that are particularly concerned about data transfers, the Commerce platform allows merchants to ask shoppers for their consent to process data overseas.[3] Though uncommon as of the

[2] Commerce may use similar or related data transfer mechanisms, such as the UK International Data Transfer Addendum (IDTA) to the SCCs, in order to facilitate data transfers out of other jurisdictions.

[3] GDPR defines consent as "any freely given, specific, informed and unambiguous indication of the data subject's wishes..., by a statement or by a clear affirmative action [that] signifies agreement to the

date of this writing, user-consent can be a powerful tool for facilitating data transfers.[4] Consent is *not* the only legal basis for transferring personal data overseas, and each merchant should decide for itself whether Commerce's extensive data protection commitments (including the SCCs and supplemental technical and organization measures) render user-consent unnecessary. You can find more information on collecting consent during account signup here.

Frequently Asked Questions (FAQs)

Does *Schrems II* mean that all personal data transfers to the United States violate GDPR?

No! Although the Court of Justice of the European Union (CJEU) invalidated the EU-US Privacy Shield as an independently adequate data transfer mechanism in 2020 as part of its *Schrems II* judgment,[5] there remain multiple GDPR-compliant legal bases for transferring EU personal data overseas that may apply to ecommerce, including: (i) SCCs with appropriate safeguards; (ii) consent; (iii) performance of a contract; or (iv) legitimate interest.[6]

Further, there have been important changes in U.S. law since the *Schrems II* judgment was issued. The CJEU's reasoning in *Schrems II* rested on concerns about foreign intelligence activities by the United States government, specifically the potential for warrantless data collection that might violate principles of recourse and proportionality articulated in Articles 47 & 52 of the EU Charter on Fundamental Rights. The United States has since placed legal restrictions on intelligence gathering to allay these concerns and to ensure required intelligence gathering is necessary, proportionate, and subject to individual recourse.

After reviewing changes in U.S. law, the European Commission issued an adequacy decision for the EU-US Data Privacy Framework[7]—a successor to the EU-US Privacy Shield. In announcing its decision, the European Commission noted that new restrictions on U.S. intelligence gathering had "addressed the issues raised by the Court of Justice of the EU in the Schrems II judgment." At this point in time the reigning transfer mechanism is the EU- US Data Privacy Framework which is now in effect.

Does Commerce rely exclusively on the EU-US Data Privacy Framework?

---

processing of personal data relating to [the data subject]". GDPR, Art. 4(11). Additional EDPB guidelines on consent can be found here.

[4] Explicit consent is a valid legal basis under GDPR for all personal data transfers overseas. GDPR, Art. 49(1)(a). Unlike other derogations, e.g. performance of a contract, the derogation for consent can be used for systematic and repetitive data transfers. GDPR, Recital 111 and EDPB guidelines on derogations, p. 4-5 ("Recital 111 differentiates among the derogations by expressly stating that the "contract" and the "legal claims" derogations (Article 49 (1) subpar. 1 (b), (c) and (e)) shall be limited to "occasional" transfers, while such limitation is absent from the "explicit consent derogation"... pursuant to Article 49 (1) subpar. 1 (a)...").

[5] CJEU judgment of 16 July 2020, Data Protection Commissioner v Facebook Ireland Ltd, Maximillian Schrems, Case C-311/18, ECLI:EU:C:2020:559 ("Schrems II").

[6] GDPR, Chapter 5 (Art. 44-50).

[7] The Data Privacy Framework ("DPF") is a voluntary framework that allows companies to transfer personal data from the EU to the United States. The DPF was developed by the U.S. Department of Commerce, the European Commission, the UK Government, and the Swiss Federal Administration. The DPF entered into force on July 10, 2023.

No. Commerce does not rely exclusively on the EU-US Data Privacy Framework or its predecessors to legitimize transatlantic data transfers. We have always and continue to carefully scrutinize any data transfer and the adequacy of any legal, security, and organizational safeguards.

While not our only transfer mechanism, Commerce continues to participate in the framework because it provides merchants and shoppers with important protections: it commits Commerce to the Privacy principles; binds us to a private dispute resolution mechanism;[8] and enables the U.S. Federal Trade Commission to enforce the terms of our privacy policy.

Will you notify us about new or expanded international transfers, and can we object?

Yes. We provide clear and timely notice about subprocessor changes or material changes to our Data Processing Addendum . As the controller, you retain the right to object to a transfer or change in our process which you believe is unlawful. We'll cooperate to evaluate alternatives or apply additional safeguards.

How much control do I have over personal data collected by my store?

By default and design, the Commerce platform is highly customizable and requires very little personal data to function; therefore, merchants have enormous latitude and choice regarding the collection and use of personal data on their storefronts.

For example, Commerce allows merchants to enable guest checkout, which minimises personal data, and delete or modify customer accounts (e.g., in response to a data subject access or deletion request). Commerce's built-in security & privacy settings also allow merchants to create cookie consent banners, customize scripts, and turn off built-in store analytics.[9] Additional privacy tools, controls, and resources may be available via third parties in the app marketplace.

You can find more information here about the storefront cookies necessary for the Commerce platform to function properly. Merchants can independently choose whether to use additional custom or third-party cookies, scripts, applications, integrations, etc., to support their own marketing or other commercial interests and activities.

Where is my data stored and processed?

Commerce primarily utilizes Google Cloud's U.S.-Central1 region as our primary data storage location, with additional locations hosted on Google Cloud's Europe-West3 and Australia-SE1 regions. Across each region, our infrastructure is replicated throughout multiple availability zones to promote resilience. See our Third Party Suprocessor page for more information about our subprocessors and where your data is stored or processed.

[8] Commerce has registered with the Association of National Advertisers (ANA) to provide independent third-party dispute resolution at no cost to the complaining party. You can contact ANA and/or learn more about the company's dispute resolution services, including instructions for submitting a complaint here. Complaining parties may also, in absence of a resolution by Commerce and ANA, seek to engage in binding arbitration through the Privacy Shield Panel.

[9] Consent and script management functionality may be necessary where merchants choose to add website analytics solutions which rely on the collection of additional personal data or IP addresses.

What is the actual risk of warrantless surveillance of the Commerce platform by U.S. authorities?

E-commerce transactions do not generate data that is of any particular interest to U.S. intelligence agencies.[10] U.S. foreign intelligence requests for personal data held in the United States are exceedingly rare and strictly controlled with many legal safeguards.[11] The Commerce platform has *never* been subjected to any request under FISA, a National Security Letter (NSL), an Executive Order, or any similar authority, and we do not expect that we will ever receive such a request.

In any event, as noted by the European Commission in its draft adequacy decision on the EU-US Data Privacy Framework, recent changes in U.S. law have made it unlikely that *any* future intelligence request will violate the proportionality and recourse principles identified in the *Schrems II* judgment.

What if Commerce receives a warrantless surveillance request from U.S. authorities?

While it is unlikely that Commerce will ever receive a U.S. intelligence request that implicates *Schrems II* concerns, we maintain an internal Government Access Request (GAR) policy to guide our response in the event that we do. Among other things, our GAR policy requires that Commerce: (i) assess the feasibility of challenging, redirecting, or narrowing an intelligence request; and (iii) take steps to minimize the production or potential misuse of any personal data sought by an intelligence request. Our GAR policy also requires that we take steps to promote transparency in the event that we receive such a request.

[10] U.S. Department of Commerce's September 2020 White Paper, Information on U.S. Privacy Safeguards Relevant to SCCs and Other EU Legal Bases for EU-U.S. Data Transfers after *Schrems II*.

[11] For example, in 2024, Section 702 of the Foreign Intelligence Surveillance Act (FISA) was only used to target 291,824 non-U.S. persons globally, representing about 0.0036% of the world's population. Annual Statistical Transparency Report, Office of the Director of National Intelligence, April 2025, p. 6. Any failure to adhere to court-approved procedures is reported to the U.S. Foreign Intelligence Surveillance Court (FISC) and the U.S. Congress in semiannual reports. *Id.*, p. 14.